

Relazione Tecnica: Architetture Cloud, Resilienza dei Dati e Sicurezza Infrastrutturale

Premessa: Il Cambio di Paradigma nella Cybersecurity

Con l'avvento della trasformazione digitale, il perimetro di sicurezza aziendale non è più definito dalle mura fisiche del data center o dai firewall perimetrali. Lo spostamento delle risorse informatiche verso il Cloud ha imposto un nuovo approccio, spesso basato sul framework *Zero Trust* (non fidarsi di nulla, verificare tutto), in cui la corretta configurazione dell'infrastruttura, le policy di backup avanzate e l'alta affidabilità dell'hardware (RAID) diventano la linea di difesa principale contro incidenti critici e attacchi ransomware.

1. Ecosistema Cloud: Analisi Comparativa dei principali Hyperscaler

Il mercato del Public Cloud è dominato da tre grandi colossi IT (i cosiddetti "Hyperscaler"). La scelta del fornitore non si basa solo sui costi, ma sull'allineamento tra le funzionalità offerte e la *Security Posture* (postura di sicurezza) dell'azienda.

Amazon Web Services (AWS)

- **Profilo Infrastrutturale:** AWS è il pioniere del settore. Vanta l'infrastruttura globale più estesa e una maturità tecnologica impareggiabile.
- **Punti di forza e Sicurezza:** Il suo ecosistema si basa su un sistema di Identity and Access Management (IAM) di una granularità estrema, che permette di applicare il principio del "Privilegio Minimo" con precisione chirurgica. Offre strumenti nativi avanzati per la Threat Detection, come *Amazon GuardDuty* (che analizza i log di rete tramite Machine Learning per individuare anomalie) e *AWS Shield* per la mitigazione degli attacchi DDoS su larga scala.
- **Target:** Ideale per aziende che necessitano di scalabilità infinita e che dispongono di team di ingegneria cloud altamente specializzati.

Microsoft Azure

- **Profilo Infrastrutturale:** La piattaforma di Microsoft ha scalato rapidamente le gerarchie diventando il secondo player mondiale. Il suo vantaggio sleale è il monopolio quasi totale di Microsoft negli ambienti aziendali tradizionali.

- **Punti di forza e Sicurezza:** Azure brilla negli ambienti "Cloud Ibrido". Grazie all'integrazione nativa con *Entra ID* (precedentemente noto come Active Directory), le aziende possono estendere le proprie policy di sicurezza, le password e le identità degli utenti dal server fisico in ufficio fino al cloud in modo trasparente. Dal punto di vista difensivo, integra *Microsoft Defender for Cloud* e *Azure Sentinel* (un sistema SIEM nativo cloud per la gestione degli incidenti informatici).
- **Target:** Grandi enterprise (Banche, Pubblica Amministrazione, Assicurazioni) che devono migrare infrastrutture legacy complesse.

Google Cloud Platform (GCP)

- **Profilo Infrastrutturale:** GCP è l'infrastruttura su cui poggiano i servizi globali di Google. È considerata la rete più veloce al mondo grazie alla posa di cavi in fibra ottica sottomarini di proprietà esclusiva.
 - **Punti di forza e Sicurezza:** Google è il leader indiscusso quando si tratta di containerizzazione (avendo inventato Kubernetes) e di elaborazione Big Data/AI. Sul fronte sicurezza, Google applica il suo modello *BeyondCorp*, la quintessenza dell'architettura Zero Trust. Le difese di GCP sono orientate a proteggere i microservizi e a crittografare i dati non solo "a riposo" (storage) e "in transito" (rete), ma anche "in uso" (Confidential Computing).
 - **Target:** Aziende tech-driven, startup e organizzazioni che fanno un uso massiccio di Intelligenza Artificiale e analisi dati.
-

2. Modelli di Erogazione e il Modello di Responsabilità Condivisa

Nella gestione del Cloud, uno dei concetti più fraintesi è quello della sicurezza. Il cloud non è "sicuro di default": la sicurezza dipende dal **Modello di Responsabilità Condivisa**, una matrice che definisce chiaramente i compiti del fornitore (sicurezza *del* cloud) e quelli del cliente (sicurezza *nel* cloud).

IaaS (Infrastructure as a Service)

- **Descrizione:** Il cloud provider fornisce l'hardware virtualizzato (CPU, RAM, Storage, Rete).
- **Esempio:** *Amazon EC2, Azure Virtual Machines*.
- **Implicazioni di Sicurezza:** In questo modello, l'utente ha il massimo controllo ma anche il massimo carico di lavoro sistemistico. L'azienda è totalmente responsabile per l'installazione delle patch del sistema operativo (Hardening), la configurazione dei firewall di rete (VPC/VNet), la crittografia dei dati e l'installazione degli antivirus/EDR.

PaaS (Platform as a Service)

- **Descrizione:** Oltre all'infrastruttura di base, il provider fornisce e gestisce il sistema operativo, il middleware e i runtime (es. server web, motori di database).
- **Esempio:** *Azure SQL Database, Google App Engine, AWS Elastic Beanstalk.*
- **Implicazioni di Sicurezza:** Il cliente non deve più preoccuparsi delle vulnerabilità del sistema operativo o di patchare i server. La responsabilità si sposta (shift-left) verso la sicurezza del codice sorgente (AppSec) e la gestione sicura del ciclo di sviluppo (approccio DevSecOps). Bisogna proteggersi da vulnerabilità come SQL Injection o Cross-Site Scripting (XSS).

SaaS (Software as a Service)

- **Descrizione:** Il software è erogato come servizio finito e pronto all'uso, accessibile via browser. L'intero stack tecnologico è gestito dal fornitore.
 - **Esempio:** *Microsoft 365, Google Workspace, Salesforce, Dropbox.*
 - **Implicazioni di Sicurezza:** L'infrastruttura è completamente fuori dal controllo del cliente. L'unico, fondamentale compito del team di sicurezza aziendale è la **Gestione delle Identità e dei Dati**. Diventa obbligatorio imporre l'Autenticazione a Due Fattori (MFA), configurare policy di Data Loss Prevention (DLP) per evitare che i dipendenti esportino dati sensibili, e utilizzare sistemi CASB (Cloud Access Security Broker) per monitorare gli accessi sospetti.
-

3. Business Continuity: Metriche e Logiche di Backup Avanzate

Un errore comune è considerare il backup come una semplice "copia" di file. Nella cybersecurity moderna, il backup è l'estrema ratio (il piano di Disaster Recovery) contro attacchi distruttivi come il Ransomware. Prima di definire *come* fare il backup, un analista deve definire due metriche di business:

- **RPO (Recovery Point Objective):** Quanti dati l'azienda può permettersi di perdere? (es. i dati delle ultime 4 ore).
- **RTO (Recovery Time Objective):** Quanto tempo il sistema può restare inattivo prima che l'azienda subisca danni economici irreparabili? (es. ripristino entro 2 ore).

La Regola d'Oro Evoluta: 3-2-1-1

La classica regola 3-2-1 (3 copie, 2 supporti, 1 off-site) è stata aggiornata per combattere i ransomware. Si è aggiunto un ultimo "1", che sta per **Off-line / Immutable**. Almeno una copia dei backup deve essere tenuta in "Air-Gap" (fisicamente scollegata dalla rete) o resa "Immutabile" (WORM - Write Once, Read Many), in modo che nemmeno un malware con privilegi di amministratore possa crittografare o cancellare i salvataggi.

Metodologie di archiviazione a confronto

1. **Backup Completo (Full):** Cattura l'intero stato della macchina.
 - *Pro:* RTO bassissimo. Il ripristino è immediato e lineare.
 - *Contro:* RPO alto (si fa di solito una volta a settimana perché congestiona la rete e i dischi).
 2. **Backup Incrementale:** Salva solo i blocchi di dati modificati dall'ultima esecuzione di *qualsiasi* tipo di backup.
 - *Pro:* Velocissimo da eseguire, occupa pochissimo spazio. Ideale per esecuzioni orarie.
 - *Contro:* In caso di disastro, il software di ripristino deve ricomporre un puzzle leggendo il Full Backup e tutti i successivi incrementali in ordine cronologico. Se un solo "anello" della catena è corrotto, il ripristino fallisce.
 3. **Backup Differenziale:** Salva tutte le modifiche cumulative avvenute dall'ultimo *Full Backup*.
 - *Pro:* Compromesso ideale. Per ripristinare il sistema servono solo 2 file: l'ultimo Completo e l'ultimo Differenziale.
-

4. High Availability (Alta Affidabilità): L'architettura RAID

*Attenzione per la Security Posture: È fondamentale chiarire una pericolosa misconcezione. Il RAID (Redundant Array of Independent Disks) garantisce la continuità operativa in caso di guasto hardware (High Availability), ma **NON è un backup**. Se un utente cancella per errore un database, o se un ransomware cifra i file, la modifica verrà replicata istantaneamente su tutti i dischi del RAID.*

Le configurazioni si differenziano in base alle necessità di I/O (Input/Output) e Fault Tolerance:

- **RAID 0 (Striping):** I dati vengono "spalmati" su più dischi.
 - *Caso d'uso:* Video editing estremo, cache temporanee.
 - *Sicurezza:* Nulla. Introduce un Single Point of Failure (SPOF). Se un disco "muore", si perde l'intero array.
- **RAID 1 (Mirroring):** Due dischi contengono gli stessi identici blocchi di dati, come in uno specchio.
 - *Caso d'uso:* Sistemi operativi di piccoli server.
 - *Sicurezza:* Ottima contro i guasti meccanici. Se si rompe il Disco A, il sistema legge dal Disco B senza interruzioni (zero downtime).

- **RAID 5 (Striping con Parità Distribuita):** Richiede almeno 3 dischi. Scrive i dati su tutti i dischi, calcolando un codice matematico (la Parità). Se un disco si fonde, il controller RAID utilizza l'algebra per "indovinare" e ricostruire i dati mancanti usando i dischi superstiti.
 - *Criticità Cyber:* Durante la ricostruzione (Rebuild) di un disco rotto, il RAID 5 subisce un forte degrado delle performance ed è vulnerabile. Se si rompe un secondo disco durante questo processo, tutti i dati vanno persi.
- **RAID 6 (Doppia Parità):** L'evoluzione del RAID 5, essenziale oggi vista la grandezza enorme dei dischi moderni. Usa due blocchi di parità e può sopravvivere alla rottura contemporanea di ben **2 dischi**.
- **RAID 10 (Striping + Mirroring - RAID 1+0):** Richiede un minimo di 4 dischi. Crea dei sottogruppi in RAID 1 (mirroring per la sicurezza) e poi unisce questi sottogruppi in RAID 0 (striping per la velocità).
 - *Caso d'uso:* Database transazionali intensivi aziendali (SQL, Oracle).
 - *Sicurezza:* È lo standard enterprise per eccellenza. Offre le performance massime possibili garantendo un'altissima tolleranza ai guasti fisici, a fronte di un costo di implementazione molto elevato (il 50% dello spazio acquistato viene usato per la ridondanza).